

PLANTILLA P55 · CUESTIONARIO DE DILIGENCIA DEBIDA A PROVEEDORES DE IA

Cuestionario de diligencia debida a proveedores de IA

Recoge las respuestas y evidencias del proveedor en los doce bloques de diligencia debida del documento 36, con la profundidad que exige su nivel N1–N3, y las valora antes de resumirlas en P14.

EN ESTE DOCUMENTO

01 Instrucciones de uso

02 Identificación

03 Escala de valoración

04 Cuestionario

05 Resumen de la valoración y traslado a P14

06 Verificación directa o por tercero (N3)

07 Anexo A · Cuestionario de IA embebida para proveedores de software ya contratado

08 Criterios de calidad

09 Aprobación y verificación

10 Control de versiones

Aviso legal y exención de responsabilidad. SEVEN-G es un marco metodológico de referencia que se ofrece «tal cual» y con fines exclusivamente informativos. No constituye asesoramiento jurídico, regulatorio, financiero ni profesional, ni garantiza el cumplimiento de ninguna norma. Las referencias a regulación general (como el Reglamento Europeo de IA, el RGPD, DORA o NIS2), a normas técnicas y a regulación específica de cada sector o jurisdicción pueden ser incompletas, no aplicar a un caso concreto o quedar desactualizadas por cambios normativos, interpretaciones o criterios de las autoridades posteriores a su fecha de consulta. **Cada organización que use SEVEN-G es la única responsable de identificar la normativa que le aplica, verificar su vigencia y certificar su propio cumplimiento regulatorio**, con el asesoramiento cualificado que corresponda. El autor no asume responsabilidad alguna por el uso que se haga de este contenido ni por las decisiones que se adopten con él. Los datos, cifras, compañías y casos de los ejemplos son ficticios o ilustrativos.

Por qué importa. La responsabilidad no se externaliza: la compañía responde ante clientes, supervisores y consejo aunque el sistema sea de un tercero (36 §2). Sin un cuestionario común, cada área pregunta lo que recuerda, las respuestas no se comparan entre proveedores y el nivel de exigencia se queda en papel. Este cuestionario convierte los doce bloques de 36 §4.3 en preguntas concretas con la evidencia que las respalda, y deja constancia de qué se verificó antes de contratar.

01

Instrucciones de uso

Aspecto	Indicación
Cuándo se usa	En la etapa 2 del ciclo del proveedor (36 §5), en la fase 3 y antes de G3, una vez fijado el nivel de exigencia preliminar en P14 §3. Se repite ante cualquier disparador de reevaluación (36 §5) y antes de renovar el contrato. El anexo A se usa con los proveedores de software ya contratado (36 §8.1) desde C1 y en cada R6.
Quién la rellena	El proveedor responde y aporta evidencias. Compras envía el cuestionario y coordina. Valoran: el responsable técnico de IA (bloques 2, 9 y 11), seguridad de la información (bloque 5), protección de datos (bloques 3, 4 y 7), asesoría jurídica (bloques 6 y 8) y el responsable de riesgos de IA (bloques 1, 10 y 12 y valoración global).
Quién la verifica	Lite: responsable de riesgos de IA; si ha valorado el cuestionario, verifica la oficina de IA o el auditor de IA. Enterprise: auditor de IA, que comprueba en G3 y G5 que la diligencia corresponde al nivel (36 §11).
Quién decide o aprueba	Según el nivel (36 §4.2): N1, responsable de producto de IA con conformidad de compras; N2, patrocinador de IA con conformidad de riesgos y de protección de datos; N3, comité de IA con conformidad de riesgos, seguridad de la información, protección de datos y asesoría jurídica.

Aspecto	Indicación
Etapas o gate	Fase 3 · G3 Viabilidad (criterios G3.20 y G3.22); revisión en R6 (R6.12). Anexo A: C1 y fase 6.
Herramienta	T09 · Registro de proveedores de IA: la fecha y el resultado de la diligencia se anotan en el bloque <i>Evaluación</i> del registro (P57 §3.3).
Documento de referencia	Documento 36 §4 (niveles y contenido del cuestionario) y §8 (IA embebida). Se usa junto a P14, que resume la evaluación.
Lite frente a Enterprise	La profundidad depende del nivel de exigencia N1–N3, no de la intensidad (36 §2, principio 2). Un proveedor N3 implica normalmente intensidad Enterprise (01 §9.2).

Reglas de cumplimentación:

- Se formulan las preguntas **del nivel del proveedor y de los niveles inferiores**: N1 responde solo las marcadas N1 (cuestionario básico), N2 las marcadas N1 y N2 (cuestionario completo), N3 todas.
- Cada respuesta relevante se respalda con **evidencia**; una afirmación sin evidencia se valora como máximo *Conforme con observaciones*.
- En N1, muchas respuestas se obtienen de las condiciones de servicio y de privacidad publicadas por el proveedor: se indica la versión y la fecha consultadas.
- Las respuestas que revelen un riesgo se trasladan a P12 con el riesgo tipo que corresponda (RT-TER-01 a RT-TER-07 del documento 33).
- *Este documento no constituye asesoramiento jurídico*. Referencias consultadas en septiembre de 2026; debe verificarse su vigencia.

02

Identificación

Campo	Contenido	Guía
Código de la relación proveedor-servicio	PRV-AAAA-NNN del registro T09 (P57).	
Proveedor	Razón social, grupo y país de establecimiento.	
Servicio o componente evaluado	Tipo de tercero de 36 §1.1: proveedor de modelos, plataforma, software con IA, integrador, proveedor de datos, componentes abiertos, socio.	
Iniciativas y sistemas vinculados	IA-AAAA-NNN · SIA-AAAA-NNN.	

Campo	Contenido	Guía
Nivel de exigencia	N1 Estándar · N2 Reforzado · N3 Crítico, según P14 §3.	
Motivo del cuestionario	Selección inicial · Disparador de reevaluación · Renovación · IA embebida (anexo A).	
Fecha de envío y de respuesta	DD-MM-AAAA.	
Persona de contacto del proveedor	Nombre y cargo de quien firma las respuestas.	
Coordinador interno	Compras o gestor de la relación.	
Versión del documento		

03

Escala de valoración

Valoración	Significado
Conforme	La respuesta cumple el requisito y está respaldada por evidencia verificable y vigente.
Conforme con observaciones	Cumple en lo esencial, pero falta evidencia, hay una debilidad menor o una condición que debe resolverse antes de la firma o antes de G5.
No conforme	No cumple o la respuesta revela un riesgo no aceptable para el nivel.
No evaluado	La pregunta no se ha formulado o no se ha podido valorar; se explica el motivo.

El resultado de cada bloque es el **peor** de sus preguntas valoradas, salvo justificación escrita del valorador.

04

Cuestionario

Columnas: **Nivel** indica desde qué nivel se formula la pregunta. **Respuesta** la completa el proveedor; **Valoración**, la compañía.

4.1 Bloque 1 · Identidad y solvencia

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
1.1	Indique razón social, grupo al que pertenece, país de establecimiento y años de actividad.	Extracto del registro mercantil o equivalente.	N1		
1.2	Describa la estructura de propiedad y cualquier cambio de control reciente o conocido.	Organigrama societario.	N2		
1.3	¿Qué seguros de responsabilidad civil profesional y de ciberriesgos mantiene, con qué coberturas y límites?	Certificados de seguro vigentes.	N2		
1.4	¿Existe algún conflicto de interés con la compañía o sus competidores relevante para el servicio?	Declaración firmada.	N2		
1.5	Aporte su situación financiera de los tres últimos ejercicios.	Cuentas anuales e informe de auditoría.	N3		
1.6	Facilite referencias de clientes con servicios comparables.	Contactos autorizados.	N3		

4.2 Bloque 2 · Servicio y modelo

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
2.1	Describa el servicio y las funciones de IA que incluye, en lenguaje comprensible.	Ficha del servicio.	N1		
2.2	¿Qué modelos usa el servicio? ¿Son propios o de terceros? Identifique al proveedor de cada modelo.	Lista de modelos y proveedores.	N2		
2.3	¿Qué versiones están en uso y cuál es su política de cambios y de retirada de versiones (preaviso, fijación de versión)?	Política de versiones; calendario de retiradas.	N2		
2.4	¿Qué documentación del modelo facilita: finalidad prevista, limitaciones conocidas, resultados de evaluación, instrucciones de uso?	Documentación del modelo.	N2		
2.5	¿Permite a la compañía hacer pruebas propias con datos representativos antes de contratar?	Condiciones del entorno de pruebas.	N2		

4.3 Bloque 3 · Datos

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
3.1	¿Usa las entradas, contextos, resultados o datos de la compañía para entrenar o mejorar modelos o para otros fines? ¿Cómo se excluye?	Condiciones de servicio; captura de la configuración.	N1		
3.2	¿Qué plazo de retención aplica a entradas, resultados y registros?	Condiciones; configuración.	N1		
3.3	¿En qué regiones se tratan y almacenan los datos?	Condiciones; configuración de región.	N1		
3.4	¿Hay transferencias internacionales? ¿Con qué garantías del capítulo V del RGPD?	Mecanismo de transferencia.	N2		
3.5	¿Cómo se cifran los datos en tránsito y en reposo y quién gestiona las claves?	Descripción técnica o informe independiente.	N2		
3.6	¿Cómo se separan los datos de distintos clientes?	Descripción de la arquitectura.	N2		
3.7	¿Cómo se borran los datos a petición y al terminar el contrato? ¿Emite certificado?	Procedimiento de borrado; modelo de certificado.	N2		
(ejemplo ilustrativo) 3.1	¿Usa las entradas...?	Condiciones de servicio y captura.	N1	«No se usan para entrenamiento en el plan empresarial; configuración desactivada por defecto.»	Conforme con observaciones: falta la captura de la configuración del entorno de la compañía.

4.4 Bloque 4 · Subencargados y cadena de suministro

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
4.1	Facilite la lista de subencargados con su ubicación y función.	Lista actualizada.	N2		
4.2	¿Cómo notifica los cambios de subencargados? ¿Hay preaviso y derecho de oposición?	Política de cambios.	N2		
4.3	¿Traslada a sus subencargados las mismas obligaciones que asume con la compañía?	Cláusula tipo o declaración.	N2		
4.4	¿Subcontrata alguna parte esencial del servicio? ¿Cómo gestiona la subcontratación en cadena?	Mapa de la cadena; política.	N3		

4.5 Bloque 5 · Seguridad

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
5.1	¿Qué certificaciones e informes independientes mantiene (por ejemplo, ISO/IEC 27001 o ISO/IEC 42001) y cubren este servicio?	Certificados con alcance y vigencia.	N2		
5.2	¿Con qué frecuencia hace pruebas de intrusión y cuándo fue la última?	Resumen ejecutivo de la última prueba.	N2		
5.3	¿Cómo gestiona las vulnerabilidades y en qué plazos las corrige?	Política de vulnerabilidades.	N2		
5.4	¿Qué protecciones aplica frente a inyección de instrucciones, fuga de información y extracción del modelo?	Descripción de controles; resultados de pruebas.	N2		
5.5	Si el servicio incluye agentes: ¿qué identidad, permisos, límites de acción e interruptor de parada tienen?	Descripción frente a los controles AG del documento 35.	N2		
5.6	¿Cómo autentica y registra el acceso de su personal a los datos de la compañía?	Política de acceso; registros.	N2		
5.7	¿Acepta pruebas adversarias de la compañía o aporta informes independientes recientes de ese tipo?	Autorización de pruebas o informe.	N3		

4.6 Bloque 6 · Cumplimiento del Reglamento de IA

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
6.1	¿Qué rol asume usted según el Reglamento de IA para este servicio (proveedor del sistema, proveedor de modelo de propósito general u otro)?	Declaración.	N2		
6.2	¿Cómo clasifica el sistema a efectos del Reglamento de IA?	Análisis de clasificación.	N2		
6.3	¿Qué documentación técnica e instrucciones de uso facilita para que la compañía cumpla sus obligaciones como responsable del despliegue (art. 26)?	Instrucciones de uso.	N2		
6.4	¿Qué registros genera el sistema y cómo accede la compañía a ellos?	Descripción de registros y plazos.	N2		
6.5	¿Qué medios ofrece para la supervisión humana?	Descripción funcional.	N2		
6.6	¿Cómo coopera en la gestión de incidentes graves y en la vigilancia posterior a la comercialización?	Procedimiento.	N2		
6.7	Si aporta un modelo de propósito general: ¿qué información y documentación facilita sobre capacidades y limitaciones (art. 53)?	Documentación para proveedores posteriores.	N2		
6.8	Si suministra componentes a un sistema de alto riesgo de la compañía: ¿acepta el acuerdo escrito del art. 25.4?	Borrador de acuerdo.	N3		

4.7 Bloque 7 · Protección de datos

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
7.1	¿Actúa como encargado del tratamiento? ¿Firma el contrato de encargo conforme al art. 28 del RGPD?	Contrato de encargo.	N1		
7.2	¿Qué medidas técnicas y organizativas aplica?	Anexo de medidas.	N2		
7.3	¿Cómo apoya las evaluaciones de impacto de la compañía?	Información facilitada.	N2		
7.4	¿Cómo apoya la atención de los derechos de los interesados?	Procedimiento.	N2		

4.8 Bloque 8 · Propiedad intelectual

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
8.1	¿Quién es titular de los resultados o qué derechos de uso tiene la compañía sobre ellos?	Condiciones.	N2		
8.2	¿Qué información facilita sobre las licencias y la procedencia de los datos de entrenamiento?	Declaración o documentación.	N2		
8.3	¿Ofrece indemnidad frente a reclamaciones por infracción derivadas del modelo o de sus datos de entrenamiento?	Cláusula de indemnidad.	N2		
8.4	Si desarrolla a medida: ¿de quién es lo desarrollado?	Propuesta contractual.	N2		

4.9 Bloque 9 · Continuidad

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
9.1	¿Qué disponibilidad compromete y cuál ha sido la real en los últimos doce meses?	Compromiso de servicio; histórico.	N2		
9.2	¿De qué terceros depende el servicio (nube, modelos) y qué ocurre si fallan?	Mapa de dependencias.	N2		
9.3	¿Tiene planes de continuidad y recuperación? ¿Qué tiempos de recuperación compromete?	Resumen del plan.	N3		
9.4	¿Cuándo probó esos planes por última vez y con qué resultado?	Informe de la prueba.	N3		

4.10 Bloque 10 · Incidentes

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
10.1	¿Cómo gestiona los incidentes y por qué canal los notifica?	Condiciones; procedimiento.	N1		
10.2	¿En qué plazo desde la detección notifica y con qué contenido mínimo?	Compromiso contractual.	N2		

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
10.3	¿Qué incidentes relevantes ha tenido el servicio en los últimos veinticuatro meses?	Relación resumida.	N2		
10.4	¿Coopera en la respuesta y en las notificaciones regulatorias de la compañía, con un plazo máximo acordado (orientativamente 24 horas o menos)?	Compromiso contractual.	N3		

4.11 Bloque 11 · Salida

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
11.1	¿En qué formatos puede exportar la compañía sus datos?	Documentación de exportación.	N1		
11.2	¿Puede exportar también configuraciones, instrucciones, registros, índices y memorias?	Documentación; prueba.	N2		
11.3	¿Qué asistencia y periodo de transición ofrece al terminar?	Propuesta contractual.	N2		
11.4	¿Cómo certifica el borrado al terminar?	Modelo de certificado (P57 §8).	N2		
11.5	¿Colabora en una prueba de portabilidad con un proveedor alternativo?	Compromiso.	N3		

4.12 Bloque 12 · Ética y uso responsable

#	Pregunta	Evidencia solicitada	Nivel	Respuesta	Valoración
12.1	¿Qué política de uso aceptable aplica y qué restricciones de uso impone?	Política publicada.	N1		
12.2	¿Cómo evalúa y gestiona el sesgo del modelo o del servicio?	Métricas y resultados de evaluación.	N2		
12.3	¿Alguna restricción de uso afecta al caso de uso de la compañía?	Análisis del valorador.	N2		

Resumen de la valoración y traslado a P14

Bloque	Resultado	Observaciones y condiciones (responsable y plazo)	Riesgo trasladado a P12
1 · Identidad y solvencia			
2 · Servicio y modelo			
3 · Datos			
4 · Subencargados y cadena			
5 · Seguridad			
6 · Reglamento de IA			
7 · Protección de datos			
8 · Propiedad intelectual			
9 · Continuidad			
10 · Incidentes			
11 · Salida			
12 · Ética y uso responsable			
(ejemplo ilustrativo) 3 · Datos	Conforme con observaciones	Aportar captura de la configuración de no entrenamiento antes de la firma; compras; 15-10-2026.	RT-TER-02

Un bloque **No conforme** en datos (3), seguridad (5) o protección de datos (7) impide usar el proveedor con datos de producción hasta resolverlo; la conclusión se registra en P14 §6.

Verificación directa o por tercero (N3)

Campo	Contenido	Guía
Tipo de verificación	Visita · Revisión documental in situ · Informe de un tercero designado.	
Alcance	Bloques y preguntas verificados.	
Fecha y responsable		
Resultado	Confirma las respuestas · Con discrepancias.	
Discrepancias y tratamiento	Pregunta, discrepancia y valoración corregida.	

Anexo A · Cuestionario de IA embebida para proveedores de software ya contratado

Se envía a los proveedores de software vigentes para identificar funciones de IA existentes o planificadas (36 §8.1, paso 1). Se prioriza el software que trata datos personales o confidenciales o que interviene en decisiones. Controla el riesgo RT-TER-06.

7.1 Preguntas al proveedor

#	Pregunta	Respuesta
A.1	¿Qué funciones de IA incluye hoy el software contratado? Descríbalas en lenguaje comprensible.	
A.2	¿Qué funciones de IA tiene planificado añadir en los próximos doce meses?	
A.3	¿Alguna se activa por defecto con las actualizaciones?	
A.4	¿Puede la compañía mantener cada función desactivada hasta evaluarla? ¿Cómo?	
A.5	¿Qué datos de la compañía trata cada función? ¿Incluyen datos personales o confidenciales?	
A.6	¿Se usan esos datos para entrenar o mejorar modelos? ¿Cómo se excluye?	
A.7	¿Qué modelos y proveedores de modelos usa cada función y dónde se tratan los datos?	

#	Pregunta	Respuesta
A.8	¿Alguna función interviene en decisiones sobre personas o ejecuta acciones por sí misma?	
A.9	¿Cómo avisa de nuevas funciones de IA y de cambios de modelo (notas de versión, preaviso)?	
A.10	¿Acepta una adenda con las cláusulas de uso de datos, ubicación, cambios de modelo y transparencia sobre funciones de IA (P56 §8)?	

7.2 Valoración y decisión de la compañía

Función de IA	Código del inventario (T02)	Datos personales o confidenciales	Interviene en decisiones o actúa (A0–A3)	¿Se puede desactivar?	Nivel N	Decisión	Riesgo RT-TER-06 registrado
	SIA-AAAA-NNN	Sí · No		Sí · No	N1 · N2 · N3	Mantener desactivada · Activar con controles · Activar como iniciativa	Sí · No
<i>(ejemplo ilustrativo)</i> Resumen automático de expedientes en el gestor documental	SIA-2026-014	Sí	A0	Sí	N2	Mantener desactivada hasta el comité de IA	No

Reglas de 36 §8.2: las funciones que traten datos personales o confidenciales **deben** permanecer desactivadas hasta su evaluación cuando la configuración lo permita; si no pueden desactivarse, se registra RT-TER-06 y se decide en el siguiente comité de IA; una función que interviene en decisiones sobre personas o actúa con nivel A2 o A3 recorre el ciclo de vida completo.

08

Criterios de calidad

#	Comprobación	Estado
1	Se han formulado todas las preguntas del nivel del proveedor y de los inferiores.	Cumple · No cumple · No aplica · Pendiente
2	Cada valoración <i>Conforme</i> está respaldada por evidencia vigente.	
3	Los doce bloques tienen resultado o se justifica que no aplican.	
4	La evaluación cubre seguridad, datos, uso para entrenar, propiedad intelectual, continuidad, dependencia y salida al nivel que corresponde (G3.20).	
5	El proveedor aporta o se compromete a aportar la documentación regulatoria que la compañía necesita (G3.22).	
6	En N3 consta la verificación directa o por tercero.	
7	Los riesgos detectados están en P12 y el resumen en P14.	
8	La diligencia está registrada en T09 con fecha y resultado; en R6 se ha revisado (R6.12).	
9	En el anexo A, cada función identificada está en el inventario con su decisión (D6.08 del documento 11).	

09

Aprobación y verificación

Función	Rol en SEVEN-G	Nombre y cargo	Fecha	Firma o referencia
Responde	Proveedor (persona autorizada)			
Coordina	Compras o gestor de la relación			
Valora	Responsable técnico de IA · seguridad de la información · protección de datos · asesoría jurídica · responsable de riesgos de IA			
Verifica	Responsable de riesgos de IA u oficina de IA (Lite) · Auditor de IA (Enterprise)			
Aprueba	Según el nivel (36 §4.2)			

Separación de funciones: quien negocia el contrato no valora ni verifica el cuestionario; quien tenga conflicto de interés con el proveedor lo declara en P03 y no participa en la valoración.

10

Control de versiones

Documento cumplimentado

Versión	Fecha	Autor	Cambios
---------	-------	-------	---------

Plantilla

Versión	Fecha	Cambios
0.1	19-09-2026	Primera versión. Doce bloques de 36 §4.3 graduados por nivel N1–N3, escala de valoración, verificación en N3 y anexo de IA embebida (36 §8).

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos) · <https://eur-lex.europa.eu/eli/reg/2016/679/oj/spa> · Parlamento Europeo y Consejo de la UE · 27-04-2016

Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de Inteligencia Artificial) · <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/spa> · Parlamento Europeo y Consejo de la UE · 13-06-2024

ISO/IEC 27001:2022 Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la seguridad de la información — Requisitos · <https://www.iso.org/standard/27001> · ISO/IEC (JTC 1/SC 27) · 25-10-2022